

Lesson 02 Demo 01

Securing a Node.js Application Using OWASP Dependency-Check

Objective: To secure a Node.js application by configuring the OWASP Dependency-Check utility, performing vulnerability audits using npm audit, and generating a dependency report to identify and address potential security issues in project dependencies

Tools required: Ubuntu Lab, Dependency check utility

Prerequisites: None

Steps to be followed:

1. Configure OWASP Dependency-Check utility for Node JS application

Step 1: Configure OWASP Dependency-Check utility for Node JS application

- 1.1 Log in to Simplilearn Ubuntu lab and navigate to the terminal. Run the following command to clone the SonarQubeNodeJS repository from GitHub to your local machine, which includes all project files:

git clone <https://github.com/anujdevopslearn/SonarQubeNodeJS.git>

```
root@ip-172-31-30-85:~# git clone https://github.com/anujdevopslearn/SonarQubeNodeJS.git
Cloning into 'SonarQubeNodeJS'...
remote: Enumerating objects: 205, done.
remote: Counting objects: 100% (104/104), done.
remote: Compressing objects: 100% (53/53), done.
remote: Total 205 (delta 59), reused 69 (delta 31), pack-reused 101 (from 1)
Receiving objects: 100% (205/205), 212.16 KiB | 11.17 MiB/s, done.
Resolving deltas: 100% (67/67), done.
```

- 1.2 Run the following command to change your current directory to the SonarQubeNodeJS folder, which you just cloned:

cd SonarQubeNodeJS/

```
root@ip-172-31-30-85:~# cd SonarQubeNodeJS/
```

Once the repository is cloned, you need to install Node JS and NPM executables on the server. These will be used while performing a dependency check.

- 1.3 Run the following command to download and execute the Node Version Manager installation script from the specified URL to install NVM:

curl -o- https://raw.githubusercontent.com/nvm-sh/nvm/v0.40.0/install.sh | bash

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# curl -o- https://raw.githubusercontent.com/nvm-sh/nvm/v0.40.0/install.sh | bash
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left     Speed
100 16555  100 16555    0     0  158k      0 --:--:-- --:--:-- --:--:-- 158k
=> nvm is already installed in /root/.nvm, trying to update using git
=> => Compressing and cleaning up git repository

=> nvm source string already in /root/.bashrc
=> bash_completion source string already in /root/.bashrc
=> Close and reopen your terminal to start using nvm or run the following to use it now:

export NVM_DIR="$HOME/.nvm"
[ -s "$NVM_DIR/nvm.sh" ] && \. "$NVM_DIR/nvm.sh" # This loads nvm
[ -s "$NVM_DIR/bash_completion" ] && \. "$NVM_DIR/bash_completion" # This loads nvm bash_completion
root@ip-172-31-30-85:~/SonarQubeNodeJS# nvm install 20
v20.18.0 is already installed.
Now using node v20.18.0 (npm v10.8.2)
```

- 1.4 Run the following command to install Node.js version 20 using Node Version Manager:

nvm install 20

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# nvm install 20
v20.18.0 is already installed.
Now using node v20.18.0 (npm v10.8.2)
root@ip-172-31-30-85:~/SonarQubeNodeJS# node -v
v20.18.0
root@ip-172-31-30-85:~/SonarQubeNodeJS# npm -v
10.8.2
root@ip-172-31-30-85:~/SonarQubeNodeJS# █
```

- 1.5 Run the following commands to display the currently active version of Node.js and npm on your system:

node -v

npm -v

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# node -v
v20.18.0
```

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# npm -v
10.8.2
root@ip-172-31-30-85:~/SonarQubeNodeJS# █
```

1.6 Run the following command to install npm dependency and perform an audit on all the vulnerabilities present in npm dependencies configured in package.json:

npm install

npm audit

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# npm install
npm warn deprecated source-map-url@0.4.1: See https://github.com/lydell/source-map-url#deprecated
npm warn deprecated urix@0.1.0: Please see https://github.com/lydell/urix#deprecated
npm warn deprecated resolve-url@0.2.1: https://github.com/lydell/resolve-url#deprecated
npm warn deprecated source-map-resolve@0.5.3: See https://github.com/lydell/source-map-resolve#deprecated
npm warn deprecated w3c-hr-time@1.0.2: Use your platform's native performance.now() and performance.timeOrigin.
npm warn deprecated abab@2.0.6: Use your platform's native atob() and btoa() methods instead
npm warn deprecated domexception@2.0.1: Use your platform's native DOMException instead
npm warn deprecated formidable@1.2.6: Please upgrade to latest, formidable@v2 or formidable@v3! Check these notes: https://bit.ly/2ZEqiaU
npm warn deprecated sane@4.1.0: some dependency vulnerabilities fixed, support for node < 10 dropped, and newer ECMAScript syntax/features added
npm warn deprecated inflight@1.0.6: This module is not supported, and leaks memory. Do not use it. Check out lru-cache if you want a good and tested way to coalesce asy
nc requests by a key value, which is much more comprehensive and powerful.
npm warn deprecated rimraf@3.0.2: Rimraf versions prior to v4 are no longer supported
npm warn deprecated @humanwhocodes/config-array@0.5.0: Use @eslint/config-array instead
npm warn deprecated @humanwhocodes/object-schema@1.2.1: Use @eslint/object-schema instead
npm warn deprecated glob@7.2.3: Glob versions prior to v9 are no longer supported
npm warn deprecated superagent@3.8.3: Please upgrade to v9.0.0+ as we have fixed a public vulnerability with formidable dependency. Note that v9.0.0+ requires Node.js v
14.18.0+. See https://github.com/ladjs/superagent/pull/1800 for insight. This project is supported and maintained by the team at Forward Email @ https://forwardemail.ne
t
```

```
added 994 packages, and audited 995 packages in 1m
```

```
59 packages are looking for funding
  run `npm fund` for details
```

```
56 vulnerabilities (1 low, 20 moderate, 9 high, 26 critical)
```

```
To address issues that do not require attention, run:
  npm audit fix
```

```
To address all issues possible (including breaking changes), run:
  npm audit fix --force
```

```
Some issues need review, and may require choosing
a different dependency.
```

```
Run `npm audit` for details.
```

```
npm notice
npm notice New minor version of npm available! 10.8.2 -> 10.9.0
npm notice Changelog: https://github.com/npm/cli/releases/tag/v10.9.0
npm notice To update run: npm install -g npm@10.9.0
npm notice
root@ip-172-31-30-85:~/SonarQubeNodeJS#
```

Note: In the above screenshot, you can see 56 vulnerabilities that need to be fixed. You can execute the **npm audit fix** command, which will update the recent version, but you still need to understand if these recent changes are stable.

1.7 Once the **npm audit** is executed, dependency vulnerabilities are reduced, as seen in the screenshot below:

```
semver 7.0.0 - 7.5.1
Severity: high
semver vulnerable to Regular Expression Denial of Service - https://github.com/advisories/GHSA-c2qf-rxjj-qqgw
fix available via `npm audit fix`
node_modules/simple-update-notifier/node_modules/semver
  simple-update-notifier 1.0.7 - 1.1.0
    Depends on vulnerable versions of semver
node_modules/simple-update-notifier
  nodemon 2.0.19 - 2.0.22
    Depends on vulnerable versions of simple-update-notifier
node_modules/nodemon

15 vulnerabilities (3 moderate, 8 high, 4 critical)

To address issues that do not require attention, run:
  npm audit fix

Some issues need review, and may require choosing
a different dependency.
root@ip-172-31-30-85:~/SonarQubeNodeJS#
```

1.8 Run the following command to download version 11.1.0 of the Dependency-Check tool from its GitHub repository:

wget

<https://github.com/jeremylong/DependencyCheck/releases/download/v11.1.0/dependency-check-11.1.0-release.zip>

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# wget https://github.com/jeremylong/DependencyCheck/releases/download/v11.1.0/dependency-check-11.1.0-release.zip
--2024-11-15 14:23:13-- https://github.com/jeremylong/DependencyCheck/releases/download/v11.1.0/dependency-check-11.1.0-release.zip
Resolving github.com (github.com)... 140.82.112.3
Connecting to github.com (github.com)|140.82.112.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://objects.githubusercontent.com/github-production-release-asset-2e65be/5663857/d76f08c7-a77c-4dad-8623-5b06f9ec55a67X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20241115%2Fus-east-1%2F%3%2Faws4_request%26X-Amz-Date=20241115T142313Z&X-Amz-Expires=300&X-Amz-Signature=dalda7992e31746474e418ea91c71a8c3066dfa998a278a28d7d64806714cedc6X-Amz-SignedHeaders=host&response-content-disposition=attachment%3B%20filename%3Ddependency-check-11.1.0-release.zip&response-content-type=application%2Foctet-stream [following]
--2024-11-15 14:23:13-- https://objects.githubusercontent.com/github-production-release-asset-2e65be/5663857/d76f08c7-a77c-4dad-8623-5b06f9ec55a67X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=releaseassetproduction%2F20241115%2Fus-east-1%2F%3%2Faws4_request%26X-Amz-Date=20241115T142313Z&X-Amz-Expires=300&X-Amz-Signature=dalda7992e31746474e418ea91c71a8c3066dfa998a278a28d7d64806714cedc6X-Amz-SignedHeaders=host&response-content-disposition=attachment%3B%20filename%3Ddependency-check-11.1.0-release.zip&response-content-type=application%2Foctet-stream
Resolving objects.githubusercontent.com (objects.githubusercontent.com)... 185.199.110.133, 185.199.111.133, 185.199.108.133, ...
Connecting to objects.githubusercontent.com (objects.githubusercontent.com)|185.199.110.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 37155531 (35M) [application/octet-stream]
Saving to: 'dependency-check-11.1.0-release.zip'

dependency-check-11.1.0-release.zip 100%[=====] 35.43M 182MB/s in 0.2s

2024-11-15 14:23:13 (182 MB/s) - 'dependency-check-11.1.0-release.zip' saved [37155531/37155531]
```

- 1.9 Run the following command to extract the contents of the **dependency-check-11.1.0-release.zip** file you downloaded:
unzip dependency-check-11.1.0-release.zip

```
root@ip-172-31-30-85:~/SonarQubeNodeJS# unzip dependency-check-11.1.0-release.zip
```

```
[INFO] Analysis Started
[INFO] Finished Archive Analyzer (5 seconds)
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Jar Analyzer (2 seconds)
[INFO] Finished Central Analyzer (1 seconds)
[ERROR] -----
[ERROR] .NET Assembly Analyzer could not be initialized and at least one 'exe' or 'dll' was scanned. The 'dotnet' executable could not be found on the path; either disable the Assembly Analyzer or add the path to dotnet core in the configuration.
[ERROR] The dotnet 8.0 core runtime or SDK is required to analyze assemblies
[ERROR] -----
[WARN] dependency skipped: node module bindings seems optional and not installed
[WARN] dependency skipped: node module file-uri-to-path seems optional and not installed
[WARN] dependency skipped: node module fsevents seems optional and not installed
[WARN] dependency skipped: node module fsevents seems optional and not installed
[WARN] dependency skipped: node module nan seems optional and not installed
[WARN] dependency skipped: node module fsevents seems optional and not installed
[INFO] Finished Node.js Package Analyzer (7 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Finished Version Filter Analyzer (0 seconds)
WARNING: A restricted method in java.lang.foreign.Linker has been called
WARNING: java.lang.foreign.Linker::downcallHandle has been called by the unnamed module
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for this module
```

```
[INFO] Finished Node.js Package Analyzer (7 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Finished Version Filter Analyzer (0 seconds)
WARNING: A restricted method in java.lang.foreign.Linker has been called
WARNING: java.lang.foreign.Linker::downcallHandle has been called by the unnamed module
WARNING: Use --enable-native-access=ALL-UNNAMED to avoid a warning for this module

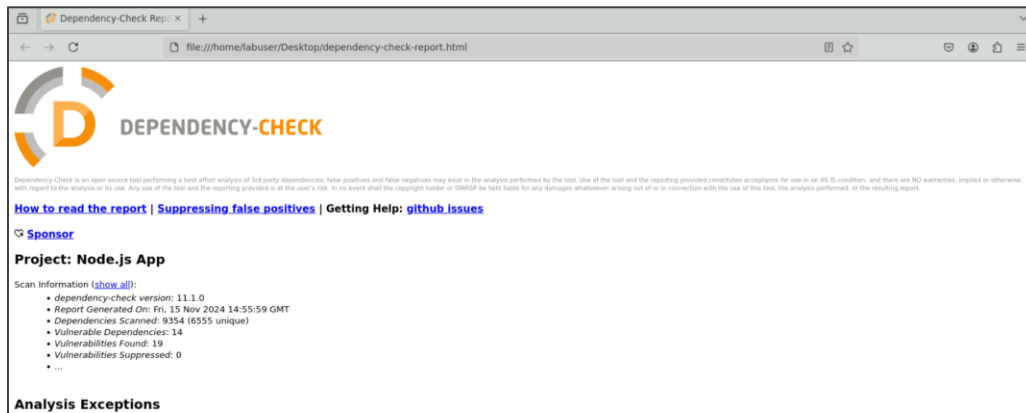
Nov 15, 2024 2:54:03 PM org.apache.lucene.store.MemorySegmentIndexInputProvider <init>
INFO: Using MemorySegmentIndexInput and native madvise support with Java 21 or later; to disable start with -Dorg.apache.lucene.store.MMapDirectory.enableMemorySegments=false
Nov 15, 2024 2:54:03 PM org.apache.lucene.internal.vectorization.VectorizationProvider lookup
WARNING: Java vector incubator module is not readable. For optimal vector performance, pass '--add-modules jdk.incubator.vector' to enable Vector API.
[INFO] Created CPE Index (6 seconds)
[INFO] Finished CPE Analyzer (21 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[INFO] Finished Node Audit Analyzer (0 seconds)
[WARN] The Yarn Audit Analyzer has been disabled. Yarn executable was not found.
[ERROR] Exception occurred initializing Yarn Audit Analyzer.
[INFO] Finished RetireJS Analyzer (80 seconds)
[INFO] Finished Sonatype OSS Index Analyzer (5 seconds)
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (8 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (135 seconds)
[INFO] Writing HTML report to: /root/SonarQubeNodeJS/./dependency-check-report/dependency-check-report.html
[ERROR] Unable to read yarn audit output.
root@ip-172-31-30-85:~/SonarQubeNodeJS#
```

1.10 Transfer dependency check report on a desktop to view it on the browser using the following command:

```
cp dependency-check-report/dependency-check-report.html /home/labuser/Desktop/
```

```
root@ip-172-31-46-237:/home/labuser# cp dependency-check-report/dependency-check-report.html /home/labuser/Desktop/
```

You will see the following interface.



Summary						
Display: Showing Vulnerable Dependencies (click to show all)						
Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
babel-cli:6.26.0	cpe:2.3:a:babelcli_project:babelcli:6.26.0:*:*:*:*:*	pkg:npm/babel-cli@6.26.0	HIGH	1	Low	7
babel-traverse:6.26.0		pkg:npm/babel-traverse@6.26.0	CRITICAL	2		7
braces:1.8.5	cpe:2.3:a:braces_project:braces:1.8.5:*:*:*:*:*	pkg:npm/braces@1.8.5	MEDIUM	2	Highest	11
braces:2.3.2		pkg:npm/braces@2.3.2	HIGH	2		3
glob-parent:2.0.0		pkg:npm/glob-parent@2.0.0	HIGH	1		8
h2:2.3.232.jar	cpe:2.3:a:h2database:h2:2.3.232:*:*:*:*:*	pkg:maven/com.h2database:h2@2.3.232	MEDIUM	1	Highest	45
javax.json:1.1.4.jar		pkg:maven/org.glassfish/javax.json@1.1.4	HIGH	1		33
json5:0.5.1	cpe:2.3:a:json5:json5:0.5.1:*:*:*:*:*	pkg:npm/json5@0.5.1	HIGH	2	Highest	7
logback-core:1.2.11.jar	cpe:2.3:a:qos.logback:1.2.11:*:*:*:*:*	pkg:maven/ch.qos.logback/logback-core@1.2.11	HIGH	1	Highest	32
micromatch:2.3.11		pkg:npm/micromatch@2.3.11	MEDIUM	1		8
micromatch:3.1.10		pkg:npm/micromatch@3.1.10	HIGH	1		8
semver:7.0.0		pkg:npm/semver@7.0.0	HIGH	2		5
source-map-support:0.4.18		pkg:npm/source-map-support@0.4.18	LOW	1		6
source-map-support:0.5.13		pkg:npm/source-map-support@0.5.13	LOW	1		6

By following the above steps, you have successfully configured the OWASP Dependency-Check utility for a Node.js application, installed Node.js and npm, performed vulnerability audits, and generated a dependency check report to identify and address potential security issues.